COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.3 · Agreement Types

Mestre CyberSec · **Aula 5.3 — Agreement Types** (5:19) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: SLA: métrica de serviço + PENA se faltar (99,9% uptime); MOU/MOA (intenção); NDA (confidencialidade); BPA (parceria formal).

💡 Highlights que a prova CompTIA cobra

- SLA: métrica de serviço + penalidade se falhar

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'agreement defining service level penalty'=SLA

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.3 — Agreement Types)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Acordo de Nível de Serviço (SLA)

Contrato vinculante que define métricas mensuráveis de desempenho de serviço (como 99,9% de uptime) e as penalidades financeiras ou ações de remediação devidas ao cliente quando essas métricas não são atingidas.

⚠ ***Armadilha CompTIA:*** *Trigger phrase: 'agreement with penalties for missing service metrics' or 'defines uptime guarantees' = ALWAYS SLA. The penalty/remediation clause is the key differentiator from MOU/MOA.*

• Memorando de Entendimento (MOU)

Documento não vinculante que expressa a intenção mútua e a disposição de duas partes de trabalharem juntas em direção a um objetivo comum, comumente usado entre organizações antes da assinatura de um contrato formal.

⚠ ***Armadilha CompTIA:*** *Trigger phrase: 'intent to cooperate' or 'non-binding agreement between organizations' = MOU. Crucially, MOUs have NO penalties and are NOT legally enforceable like an SLA.*

• Memorando de Acordo (MOA)

Documento que descreve os termos e detalhes de um arranjo acordado entre as partes, mais formal e específico que um MOU, mas tipicamente menos vinculante que um contrato completo.

⚠ ***Armadilha CompTIA:*** *Exam trap: MOA vs MOU are very similar — if the question specifies 'detailed responsibilities' or 'cooperative research/project work,' choose MOA; if it specifies 'general intent' between organizations, choose MOU.*

• Acordo de Confidencialidade (NDA)

Contrato legalmente vinculante que estabelece uma relação de confidencialidade entre as partes, proibindo o compartilhamento de informações proprietárias, sensíveis ou classificadas com terceiros não autorizados.

⚠ ***Armadilha CompTIA:*** *Trigger phrase: 'protects confidential information,' 'prevents sharing of trade secrets,' or 'employee/contractor confidentiality' = ALWAYS NDA. One-way (unilateral) or mutual (bilateral) variants both exist.*

• Acordo de Parceria de Negócios (BPA)

Contrato formal e legalmente vinculante entre dois ou mais sócios que define a divisão de lucros/prejuízos, responsabilidades de gestão e a estrutura legal do joint venture.

⚠ ***Armadilha CompTIA:*** *Trigger phrase: 'formal partnership,' 'defines roles and profit sharing between businesses,' or 'joint venture terms' = BPA. Exam tip: must be signed BEFORE sharing confidential info — always pair with an NDA.*

• Acordo Mestre de Serviços (MSA)

Contrato guarda-chuva de nível superior que estabelece os termos e condições gerais sob os quais múltiplos Escopos de Trabalho (SOWs) específicos serão executados entre cliente e fornecedor.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'umbrella agreement governing multiple future projects' or 'framework contract with vendor' = MSA. The MSA reduces negotiation time for each new project because terms are pre-agreed.*

- **Escopo de Trabalho (SOW)**

Documento detalhado que define os entregáveis específicos, cronograma, marcos e critérios de aceitação para um projeto individual executado sob um MSA ou contrato mais amplo.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'defines specific project deliverables and timeline' = SOW. Distinguish from SLA: SOW defines WHAT is delivered; SLA defines HOW WELL it is delivered (with metrics/penalties).*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Acordo de Nível de Serviço (Service Level Agreement - SLA)

🏠 **Analogia Intuitiva:** O contrato de aluguel de um gerador a diesel para um estádio de futebol durante a final de um campeonato: o contrato define em números exatos que o fornecedor garante 99,99% de tempo de energia contínua e, caso a energia caia por mais de 30 segundos, o fornecedor é obrigado por lei a pagar uma multa indenizatória de R$ 500.000 para cobrir o prejuízo do evento. Estabelece métricas claras e penalidades financeiras.

🔍 **Causa Raiz / Por que foi criado:** Provedores de serviços prometendo verbalmente disponibilidade total, mas demorando dias para consertar problemas quando não há penalidade financeira expressamente acordada.

🛡️ **Visão do Auditor de GRC:** Auditar as cláusulas de SLA: verificar se as métricas de tempo de atividade (uptime), tempo de resposta (MTTR) e créditos de serviço (penalidades por descumprimento) estão vinculadas a monitoramento automatizado e auditável.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'contract specifying guaranteed performance metrics, uptime percentages, and financial penalties for non-performance' = Service Level Agreement (SLA).

📌 Acordo de Não Divulgação (Non-Disclosure Agreement - NDA)

🏠 **Analogia Intuitiva:** O pacto de silêncio e juramento de segredo assinado por técnicos convidados a testar o protótipo ultrassecreto de um novo smartphone antes do lançamento oficial mundial da fabricante: o documento estipula que qualquer foto, vazamento ou conversa sobre o projeto em redes sociais resultará em processos judiciais multimilionários e demissão imediata.

🔍 **Causa Raiz / Por que foi criado:** O risco crítico de parceiros comerciais, prestadores de serviço ou novos contratados copiarem fórmulas secretas, códigos-fonte e segredos industriais e venderem para a concorrência.

🛡️ **Visão do Auditor de GRC:** Verificar se NDAs bilaterais ou unilaterais são assinados ANTES de qualquer compartilhamento de dados confidenciais ou reuniões técnicas de planejamento com terceiros.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'legal agreement between parties designed to protect proprietary information and intellectual property from unauthorized disclosure' = Non-Disclosure Agreement (NDA).

📌 Memorando de Entendimento (MOU) vs Memorando de Acordo (MOA)

🏠 **Analogia Intuitiva:** O noivado informal versus o contrato formal de união estável assinado em cartório. O MOU é o aperto de mãos no jantar de noivado onde as famílias declaram intenção amigável de se unir no futuro (não vinculativo, sem obrigações financeiras ou jurídicas imediatas). O MOA é o contrato registrado no cartório com compromissos específicos, obrigações detalhadas e responsabilidades formais entre as partes.

🔍 **Causa Raiz / Por que foi criado:** A necessidade de estabelecer estágios preliminares de alinhamento entre órgãos governamentais ou empresas parceiras antes de investir fortunas na elaboração de contratos definitivos.

🛡️ **Visão do Auditor de GRC:** Checar se MOUs não estão sendo usados indevidamente para transferência de dados confidenciais ou prestação de serviços sem salvaguardas contratuais vinculantes, exigindo evolução para MOA ou contrato pleno.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'non-binding agreement defining general mutual intent and cooperation' = MOU. 'More formal agreement detailing specific shared responsibilities and obligations' = MOA.

📌 Acordo de Interconexão Segura (ISA) e Acordo de Parceria Comercial (BPA)

🏠 **Analogia Intuitiva:** A construção de um túnel subterrâneo exclusivo com portas de aço e leitores biométricos ligando a sala de operações de dois bancos parceiros (o ISA é a planta de engenharia militar que especifica a espessura do concreto, os cabos de fibra criptografados e os protocolos de tráfego do túnel). O BPA (Business Partners Agreement) é o contrato comercial entre os diretores definindo a partilha de lucros, taxas de câmbio e a governança da sociedade comercial.

🔍 **Causa Raiz / Por que foi criado:** Conectar duas redes corporativas distintas através de VPNs dedicadas sem especificar controles técnicos mandatórios cria pontes diretas para infecção lateral caso um dos lados seja comprometido.

🛡️ **Visão do Auditor de GRC:** Auditar o documento ISA (conforme NIST SP 800-47): checar se especifica os requisitos de criptografia do túnel (IPsec), portas autorizadas, IPs de origem/destino e regras de desconexão emergencial unilateral.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'technical document that specifies the security requirements, encryption, and protocols for connecting two separate networks' = Interconnection Security Agreement (ISA). 'Agreement defining business expectations between commercial partners' = BPA.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Contrato de hospedagem em nuvem define 99,99% de tempo de funcionamento com descontos na fatura caso o serviço sofra paradas não programadas	**Acordo de Nível de Serviço (Service Level Agreement - SLA)**
Consultor externo assina termo legal prometendo manter em segredo absoluto os diagramas de rede e planos de negócios que verá durante a auditoria	**Acordo de Não Divulgação (Non-Disclosure Agreement - NDA)**
Duas instituições assinam documento preliminar não vinculativo manifestando desejo mútuo de colaborar em pesquisa espacial	**Memorando de Entendimento (Memorandum of Understanding - MOU)**
Documento técnico oficial entre agências que detalha a criptografia IPsec, portas liberadas e protocolo de conexão de link direto entre redes	**Acordo de Segurança de Interconexão (Interconnection Security Agreement - ISA)**
Duas corporações assinam contrato comercial que estabelece divisão de lucros, responsabilidades operacionais e governança de uma parceria	**Acordo de Parceria Comercial (Business Partners Agreement - BPA)**
Documento formal com obrigações e responsabilidades detalhadas entre partes, mais específico e com maior peso jurídico do que um simples MOU	**Memorando de Acordo (Memorandum of Agreement - MOA)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um provedor de segurança de e-mail em nuvem descumpriu repetidamente a meta de disponibilidade declarada em contrato. O gerente de segurança quer um documento que defina como o uptime é calculado, os tempos de resposta do suporte e os créditos de serviço que o provedor deve emitir quando as metas não forem atingidas. Qual tipo de acordo deve ser usado para documentar esses compromissos?

A) Acordo de parceria comercial (BPA)

B) Acordo de confidencialidade (NDA)

C) Acordo de nível de serviço (SLA)

D) Memorando de entendimento (MOU)

QUESTÃO 2 · CENÁRIO DE EXAME

Duas organizações estão considerando um projeto-piloto para trocar inteligência de ameaças anonimizada. Elas querem documentar a intenção compartilhada de cooperar, mas nenhum lado quer criar obrigações financeiras ou compromissos legalmente exigíveis até que o piloto seja bem-sucedido. Qual tipo de acordo se encaixa melhor nessa situação?

A) Memorando de entendimento (MOU)

B) Acordo de nível de serviço (SLA) assegurando a responsabilização e supervisão de fornecedores

C) Acordo de parceria comercial (BPA)

D) Declaração de trabalho (SOW) para satisfazer controles de auditoria de certificações externas

QUESTÃO 3 · CENÁRIO DE EXAME

Antes que uma empresa externa de forense receba configurações de firewall, logs de endpoint e relatórios de incidentes durante uma investigação de violação ativa, a equipe jurídica quer uma promessa legalmente exigível de que a empresa não divulgará nem usará indevidamente os dados sensíveis. Qual tipo de acordo deve ser assinado?

A) Acordo de nível de serviço (SLA)

B) Acordo de confidencialidade (NDA)

C) Contrato mestre de serviços (MSA)

D) Declaração de trabalho (SOW) preservando a cadeia de custódia e a integridade forense

QUESTÃO 4 · CENÁRIO DE EXAME

Duas empresas de cibersegurança planejam criar um serviço conjunto de detecção e resposta gerenciadas. Elas precisam definir percentuais de propriedade, divisão de receita, governança, responsabilidade e condições de término em um arranjo formal e legalmente vinculante. Qual tipo de acordo é mais apropriado?

A) Memorando de entendimento (MOU) em conformidade com critérios de análise de impacto no negócio

B) Acordo de confidencialidade (NDA) para satisfazer controles de auditoria de certificações externas

C) Acordo de nível de serviço (SLA) preservando a cadeia de custódia e a integridade forense

D) Acordo de parceria comercial (BPA)

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa espera contratar um provedor de segurança gerenciada para vários projetos nos próximos três anos. O jurídico quer um contrato que estabeleça termos padrão legais, de pagamento, responsabilidade e resolução de disputas para todo o relacionamento, enquanto o escopo de cada projeto pode ser adicionado depois. Qual tipo de acordo deve ser usado para os termos padrão?

A) Contrato mestre de serviços (MSA)

B) Declaração de trabalho (SOW) preservando a cadeia de custódia e a integridade forense

C) Acordo de nível de serviço (SLA)

D) Memorando de acordo (MOA)

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa de varejo contrata um consultor para uma avaliação única de lacunas de PCI DSS. O gerente de segurança deve especificar os entregáveis da avaliação, cronograma, atribuições de recursos, critérios de aceitação e custo fixo para este único trabalho. Qual documento é mais apropriado?

A) Contrato mestre de serviços (MSA)

B) Memorando de acordo (MOA)

C) Declaração de trabalho (SOW)

D) Acordo de confidencialidade (NDA)

QUESTÃO 7 · CENÁRIO DE EXAME

Um banco regional e um fornecedor de inteligência de ameaças querem um acordo escrito mais formal do que uma simples declaração de intenção para documentar um programa de cooperação para exercícios de mesa conjuntos, intercâmbio de equipe e pesquisa compartilhada. O documento listará atividades, papéis e recursos específicos, mas nenhuma das partes quer que ele seja legalmente exigível. Qual tipo de acordo melhor atende a essa necessidade?

A) Acordo de nível de serviço (SLA)

B) Acordo de parceria comercial (BPA)

C) Acordo de confidencialidade (NDA)

D) Memorando de acordo (MOA)

QUESTÃO 8 · CENÁRIO DE EXAME

Durante uma análise de risco de fornecedor, a equipe de segurança descobre que um provedor SaaS crítico possui um MSA, um NDA e uma SOW, mas nenhum documento declara o percentual de uptime exigido ou os créditos financeiros devidos se o serviço ficar abaixo desse percentual. Qual tipo de acordo está faltando?

A) Acordo de confidencialidade (NDA)

B) Acordo de nível de serviço (SLA)

C) Memorando de entendimento (MOU)

D) Declaração de trabalho (SOW) para atender a normas regulatórias obrigatórias de governança

QUESTÃO 9 · CENÁRIO DE EXAME

Um gerente de segurança está negociando com um fornecedor SaaS. Antes de permitir que os engenheiros do fornecedor acessem amostras de dados de produção durante uma prova de conceito, o gerente quer um documento legalmente vinculante que impeça a divulgação ou reutilização dos dados para qualquer finalidade além da avaliação. Qual tipo de acordo deve ser usado?

A) Acordo de confidencialidade (NDA)

B) Acordo de parceria comercial (BPA)

C) Memorando de entendimento (MOU)

D) Acordo de nível de serviço (SLA)

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa já possui um MSA com um fornecedor de segurança em nuvem. Para uma nova migração de SIEM, a equipe de segurança precisa definir as tarefas de segurança específicas do projeto, marcos, testes de aceitação e entregáveis que não estão cobertos nos termos mestres. Qual documento deve ser criado?

A) Acordo de nível de serviço (SLA)

B) Memorando de acordo (MOA)

C) Acordo de confidencialidade (NDA)

D) Declaração de trabalho (SOW)

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Acordo de nível de serviço (SLA)
Um SLA define níveis mensuráveis de serviço, como disponibilidade e tempo de resposta, e inclui remédios ou penalidades quando o provedor não os cumpre. Um BPA rege uma parceria comercial formal, um NDA protege informações confidenciais e um MOU registra intenções, não métricas de serviço exigíveis.

Questão 2: Alternativa A — Memorando de entendimento (MOU)
Um MOU é usado para registrar um entendimento ou intenção mútua entre as partes, geralmente antes de um contrato formal. Normalmente é menos formal e não vinculante. Um SLA define métricas de serviço, um BPA formaliza uma parceria comercial e uma SOW detalha entregáveis específicos de projeto.

Questão 3: Alternativa B — Acordo de confidencialidade (NDA)
Um NDA é projetado para proteger informações confidenciais e criar obrigações legais que impedem divulgação ou uso indevido não autorizado. Um SLA cobre desempenho de serviço, um MSA fornece termos contratuais abrangentes e uma SOW define entregáveis do projeto.

Questão 4: Alternativa D — Acordo de parceria comercial (BPA)
Um BPA é usado para estabelecer e reger formalmente uma parceria comercial, incluindo propriedade, arranjos financeiros, responsabilidades e rescisão. Um MOU geralmente é uma intenção não vinculante, um NDA protege confidencialidade e um SLA define métricas de desempenho de serviço.

Questão 5: Alternativa A — Contrato mestre de serviços (MSA)
Um MSA fornece os termos legais e comerciais abrangentes que regem todo o trabalho futuro entre as partes. SOWs individuais podem então definir escopo e entregáveis específicos do projeto. Um SLA define métricas de serviço, e um MOA registra um acordo de cooperação que frequentemente não é vinculante.

Questão 6: Alternativa C — Declaração de trabalho (SOW)
Uma SOW define o trabalho específico a ser realizado em um projeto, incluindo entregáveis, cronograma, recursos, critérios de aceitação e custo. Um MSA estabelece termos gerais para um relacionamento contínuo, um MOA documenta um acordo de cooperação e um NDA protege informações confidenciais.

Questão 7: Alternativa D — Memorando de acordo (MOA)
Um MOA é mais formal que um MOU e pode descrever atividades cooperativas, papéis e recursos específicos, embora frequentemente permaneça não vinculante, a menos que seja incorporado a um contrato. Um SLA define níveis de serviço, um BPA cria uma parceria formal e um NDA protege informações confidenciais.

Questão 8: Alternativa B — Acordo de nível de serviço (SLA)
O SLA é o tipo de acordo que registra níveis mensuráveis de serviço, como uptime, e remédios ou penalidades quando esses níveis não são atingidos. O MSA fornece termos gerais, o NDA protege confidencialidade e a SOW define entregáveis do projeto.

Questão 9: Alternativa A — Acordo de confidencialidade (NDA)
Um NDA é usado para proteger dados confidenciais e cria restrições legais de divulgação e uso. Um BPA é para parcerias comerciais formais, um MOU documenta intenções e um SLA define métricas de desempenho de serviço.

Questão 10: Alternativa D — Declaração de trabalho (SOW)
Uma SOW é usada com um MSA para definir o escopo, as tarefas, os marcos e os entregáveis específicos de um determinado projeto. Um SLA define métricas de serviço, um MOA registra atividades de cooperação e um NDA protege informações confidenciais.